

SWitCH Cyber - Pós-Graduação em Segurança de Informação, Cibersegurança e Privacidade

**Auditoria da Segurança de Informação (ASINF)
Professor Hermano Correia**

Plano de Auditoria de
Sistemas de Informação para a "Ferroviária Tech"

Group 3:

Sara Bastos, 1250420

Marta Ferreira, 1201845

José Rodrigues, 1940368

PLANO DE AUDITORIA

ORGANIZAÇÃO A AUDITAR	
DATA DE ENVIO DO PLANO DE AUDITORIA	2026/05/21
DESIGNAÇÃO LEGAL DA ORGANIZAÇÃO	Ferrovária Tech, S.A.
REPRESENTANTE DA ORGANIZAÇÃO	Dr. João Maria - Diretor de Tecnologia e Inovação
CONTACTO	joao.maria@ferroviaria-tech.pt +351 210 000 001
ÂMBITO DE CERTIFICAÇÃO	Sistemas de Informação aplicados ao setor ferroviário: desenvolvimento, implementação e manutenção de sistemas críticos de controlo de tráfego, bilhética eletrónica, monitorização de infraestrutura e gestão operacional.
AUDITORIA	
AUDITORIA	Auditoria de Sistemas de Informação - Avaliação de Conformidade e Segurança
DATA DA AUDITORIA	1 de Junho de 2026 a 7 de Agosto de 2026 (10 semanas)
TIPO DE AUDITORIA	☐ Totalmente presencial ☐ Totalmente remota ☒ Parcialmente remota
CRITÉRIOS DE AUDITORIA	
CRITÉRIOS DE AUDITORIA	- ISO/IEC 27001:2022 - Requisitos do Sistema de Gestão de Segurança da Informação (SGSI) - ISO/IEC 27002:2022 - Controlos de segurança da informação - RGPD (Regulamento UE 2016/679) - Proteção de dados pessoais - Diretiva NIS2 (UE 2022/2555) - Segurança de redes e sistemas de informação - ISO/IEC 27005:2022 - Gestão de risco de segurança da informação - IEC 62443 - Segurança de sistemas de automação e controlo industrial (OT/SCADA) - COBIT 2019 - Governança e gestão de TI empresarial
OBJETIVOS DE AUDITORIA	
OBJETIVOS DE AUDITORIA	- Verificar a implementação e eficácia dos controlos de segurança - Avaliar a conformidade com o RGPD - Examinar o processo de gestão de risco de segurança da informação - Rever os planos de continuidade (BCP) e recuperação de desastres (DRP) - Auditar a segurança da infraestrutura de rede, sistemas e ambientes cloud - Avaliar a gestão de identidades e acessos (IAM/PAM), incluindo MFA - Verificar os controlos de segurança aplicados aos sistemas OT/SCADA ferroviários - Avaliar a gestão de fornecedores e segurança da cadeia de fornecimento

ÂMBITO DE AUDITORIA	
ÂMBITO DE AUDITORIA	Sistemas de Informação e infraestrutura tecnológica da Ferroviária Tech, S.A., abrangendo: • Sistema de Gestão de Tráfego Ferroviário (SGTF) • Plataforma de Bilhética Eletrónica • Plataformas de manutenção • Sistema de Monitorização de Infraestrutura (SMI / OT/SCADA) • ERP corporativo, portal de colaboração e sistema de gestão documental • Infraestrutura de rede, data centers (Lisboa, Porto, Aveiro) e ambientes cloud Processos: • Gestão de acessos • Gestão de incidentes • Continuidade • Fornecedores • RGPD
ATIVIDADES E PROCESSOS A AUDITAR	1. Políticas e procedimentos de segurança da informação 2. Controlo de acessos lógicos e físicos, gestão IAM/PAM, MFA 3. Gestão de vulnerabilidades, patch management e testes de penetração 4. Criptografia e gestão de chaves 5. Segurança da infraestrutura de rede, cloud (Azure) e ambientes OT/SCADA 6. Gestão de incidentes de segurança e resposta a incidentes 7. Conformidade RGPD: registo de tratamentos, bases legais, direitos dos titulares, DPIA 8. Planos BCP/DRP — revisão documental e resultados de testes (RTO/RPO) 9. Gestão de fornecedores e terceiros — contratos, due diligence, acessos remotos 10. Formação e consciencialização em segurança (security awareness)
LOCAIS A AUDITAR	• Sede: Lisboa (Escritório Central + Data Center Primário) • Centro de Operações Ferroviárias: Porto (SGTF, SMI, OT/SCADA) • Data Center de Recuperação de Desastres: Aveiro (BCP/DRP, Backup) • Infraestrutura Cloud: Microsoft Azure (revisão remota de configurações)
NÚMERO DE TURNOS	1 turno diário (horário normal de expediente)
HORÁRIO DOS TURNOS	09:00 - 18:00 (com pausa para almoço das 13:00 às 14:00)

PLANO DE AUDITORIA

IDIOMAS		
IDIOMAS	Português	
AUDITORIA REMOTA		
AUDITORIA REMOTA	Técnicas planeadas: • Videoconferência via Microsoft Teams: entrevistas e reuniões de abertura/encerramento • Revisão assíncrona de documentos: políticas, registos, contratos (plataforma segura) • Acesso read-only remoto a consolas de administração Azure (sessão supervisionada) • Partilha de ecrã para demonstração de configurações de segurança	
EQUIPA AUDITORA		
NOME	FUNÇÃO	PARTICIPAÇÃO
Ana Costa - Auditores Associados, Lda.	Auditora Coordenadora (CISA, CRISC)	10 semanas
Miguel Ferreira - Auditores Associados, Lda.	Auditor Sénior - Segurança SI (CISSP, CEH)	6 semanas
Sofia Lopes - Auditores Associados, Lda.	Auditora - Proteção de Dados (CIPP/E, DPO)	5 semanas
Rui Santos - Auditores Associados, Lda.	Auditor Técnico - Infraestrutura (CCNA, Sec+)	4 semanas
Catarina Neves - Auditores Associados, Lda.	Auditora - Continuidade e Risco (ISO 22301)	4 semanas
Contacto da Auditora Coordenadora: ana.costa@auditores-associados.pt +351 210 000 100		

PLANO DE AUDITORIA

AGENDA DA AUDITORIA

As atividades de auditoria remota estão assinaladas na coluna Método/Meio. A coluna Local Auditor indica a localização física da equipa auditora.

Data	Local Auditado	Local Auditor	Método/Meio	Hora	Assuntos/Processos	Auditor
01/06/2026	Sede (Lisboa)	Sede (Lisboa)	Presencial	09:00	Reunião de abertura: Apresentação da equipa auditora, confirmação de âmbito e agenda	Ana Costa
01/06/2026	Sede (Lisboa)	Sede (Lisboa)	Presencial	10:00	Entrevista: Diretor de TI / CISO - Políticas de SI, governança e gestão de risco	Ana Costa
01/06/2026	Sede (Lisboa)	Sede (Lisboa)	Presencial	14:00	Revisão documental: Políticas de segurança, SGSI, registo de ativos e classificação de dados	Miguel Ferreira
01/06/2026	Sede (Lisboa)	Sede (Lisboa)	Presencial	16:00	Entrevista: DPO - Conformidade RGPD, registo de tratamentos, DPIA	Sofia Lopes
02/06/2026	Sede (Lisboa)	Sede (Lisboa)	Presencial	09:00	Inspeção técnica: controlo de acessos físicos, CCTV, clear desk/screen	Rui Santos
02/06/2026	Sede (Lisboa)	Sede (Lisboa)	Presencial	10:30	Revisão: Gestão IAM/PAM - AD, contas privilegiadas, MFA, revisão periódica de acessos	Miguel Ferreira
02/06/2026	Sede (Lisboa)	Sede (Lisboa)	Presencial	14:00	Revisão: Gestão de vulnerabilidades, patch management, resultados de pentests	Rui Santos
02/06/2026	Sede (Lisboa)	Sede (Lisboa)	Presencial	16:00	Entrevista: Gestor de Continuidade, BCP/DRP, RTO/RPO, resultados de testes	Catarina Neves
08/06–12/06	Porto (COF)	Porto (COF)	Presencial	09:00	Auditoria OT/SCADA: SGTF, SMI - segregação IT/OT, firmware, protocolos industriais, acessos remotos	Miguel Ferreira
08/06–12/06	Porto (COF)	Porto (COF)	Presencial	14:00	Inspeção: segurança física do Centro de Operações Ferroviárias e sala de controlo	Rui Santos
15/06–26/06	Sede (Lisboa)	Sede (Lisboa)	Presencial	09:00	Auditoria RGPD: base legal de tratamentos, direitos dos titulares, transferências internacionais, fornecedores-subcontratantes (Art. 28)	Sofia Lopes
15/06–26/06	Remoto (Azure)	Teletrabalho	Remoto / MS Teams + screen share	14:00	Revisão configurações cloud Azure: IAM, logging, encriptação, network security groups, backup	Rui Santos
29/06–10/07	Aveiro (DC DR)	Aveiro	Presencial	09:00	Data Center DR: infraestrutura de backup, replicação, testes	Catarina Neves

PLANO DE AUDITORIA

					BCP/DRP, continuidade de negócio	
29/06-10/07	Sede (Lisboa)	Sede (Lisboa)	Presencial	14:00	Revisão: Gestão de fornecedores - contratos, due diligence, monitorização, acessos remotos de terceiros	Ana Costa
13/07-24/07	-	Teletrabalho	Remoto / assíncrono	09:00	Análise e consolidação de evidências - Análise GAP ISO 27001 e RGPD, classificação de não conformidades	Equipa completa
27/07-07/08	-	Teletrabalho	Remoto / MS Teams	09:00	Elaboração de relatório preliminar, management response, incorporação de comentários	Ana Costa
07/08/2026	Sede (Lisboa)	Sede (Lisboa)	Presencial	10:00	Reunião de encerramento: Apresentação de constatações, conclusões e próximos passos	Ana Costa
07/08/2026	Sede (Lisboa)	Sede (Lisboa)	Presencial	12:00	Fim da auditoria: Entrega do Relatório Final	Ana Costa

PLANO DE AUDITORIA

DOCUMENTAÇÃO A DISPONIBILIZAR	
DOCUMENTAÇÃO A DISPONIBILIZAR	A equipa auditora solicita que os seguintes documentos e registos estejam disponíveis antes do início da auditoria: POLÍTICAS E SGSI • Política de Segurança da Informação e políticas subordinadas • Manual do SGSI e declaração de aplicabilidade (SoA - ISO 27001) • Registo de ativos de informação e classificação de dados • Registo de riscos e plano de tratamento de riscos PROTEÇÃO DE DADOS (RGPD) • Registo das atividades de tratamento de dados • Avaliações de impacto (DPIA) realizadas • Contratos com subcontratantes de dados • Procedimentos de exercício de direitos dos titulares INFRAESTRUTURA E TÉCNICA • Diagramas de arquitetura de rede (IT e OT/SCADA) • Relatórios de scanning de vulnerabilidades (últimos 12 meses) • Relatórios de testes de penetração (últimos 2 anos) • Logs de SIEM e relatórios de incidentes de segurança CONTINUIDADE E FORNECEDORES • Plano de Continuidade de Negócio (BCP) e Plano de Recuperação de Desastres (DRP) • Resultados dos últimos testes de BCP/DRP • Contratos com fornecedores críticos de TI e cláusulas de segurança FORMAÇÃO • Registos de formação em segurança da informação e consciencialização (últimos 2 anos)
OBSERVAÇÕES	
OBSERVAÇÕES	A equipa auditora solicita que a organização: • Verifique se a informação sobre a organização constante neste plano está correta • Disponibilize a documentação solicitada no campo anterior até 26 de maio de 2026 • Assegure que, para cada elemento da equipa auditora, existe um interlocutor disponível para acompanhamento presencial ou remoto conforme indicado na agenda • Garanta a disponibilidade das seguintes funções para entrevista: CISO / Responsável de SI, DPO (Data Protection Officer), Administrador de Sistemas / Infraestrutura, Responsável de Operações Ferroviárias (OT/SCADA), Gestor de Continuidade de Negócio, Gestor de Contratos e Fornecedores • Verifique a operacionalidade dos meios tecnológicos para atividades remotas (MS Teams, acesso à consola Azure) • Verifique a exequibilidade da agenda proposta e comunique necessidade de alterações com antecedência mínima de 5 dias úteis

	• Divulgue o presente plano ao pessoal relevante para garantir disponibilidade e participação. Se, durante a auditoria, for verificada a impossibilidade de atingir os objetivos previstos devido à utilização das TIC, poderá ser decidido pela EA a realização dessas atividades presencialmente. Este plano poderá ser revisto no decurso da auditoria, por sugestão da Equipa Auditora (EA) ou da organização. O horário para almoço é uma estimativa, serão sempre cumpridos os horários da empresa. A auditoria não pode ser gravada.
--	---

LISTA DE DISTRIBUIÇÃO DO RELATÓRIO DE AUDITORIA	
LISTA DE DISTRIBUIÇÃO	Após a conclusão da auditoria, o Relatório Final será disponibilizado aos seguintes destinatários: • Representante da organização: Dr. João Maria (Diretor de TI) • Diretor-Geral / CEO da Ferroviária Tech • CISO / Responsável de Segurança da Informação • DPO (Data Protection Officer) • Auditora Coordenadora: Ana Costa (arquivo da equipa auditora) O relatório tem classificação CONFIDENCIAL e não deve ser distribuído externamente sem autorização expressa da Ferroviária Tech, S.A.